

Relatório de Teste de Invasão

Weather Forecast — versão 6.2.2 (site publicado em GitHub Pages)

Item	Detalhe
Metodologia	OSSTMM 3 (Open Source Security Testing Methodology Manual, ISECOM) — canal Redes de Dados, aplicado a uma aplicação web estática e aos processos do repositório
Data	03/10/2026
Solicitante / dono do sistema	Dalmo Costa (autorizou o teste)
Executor	Claude (assistente de IA), de forma automatizada e com revisão de código
Alvo	Código da versão 6.2.2 (commit 20e6337), servido localmente de forma idêntica ao publicado; repositório GitHub dalmoacosta-EmetOS/previsao-tempo
Tipo	Caixa-cinza (código conhecido), sem dano, com todos os serviços externos simulados
Resultado	33 de 42 vetores de ataque resistiram · nenhuma falha crítica · 11 limitações registradas (1 alta, 4 médias, 5 baixas, 1 informativa)

Nota de publicação. Este relatório ficou fora do repositório público até as correções (divulgação responsável). As limitações de código e de processo foram corrigidas na versão 6.3.0 no mesmo dia: ver *pentest-2026-10-03-v6.3.0-reteste.pdf*.

1. Resumo executivo

Verdade de partida: o site está bem protegido contra os ataques mais comuns em sites (injeção de código, roubo de dados por scripts, embutir o site em outro para enganar cliques). **O maior risco hoje não está no código: está na conta e no repositório do GitHub**, que podem trocar o site inteiro se forem invadidos — e o ramo principal está sem proteção.

Pergunta	Resposta
Alguém consegue rodar código malicioso no site?	Não, em nenhum dos 21 vetores de injeção testados (links, respostas de 7 serviços externos, armazenamento do aparelho). A política de segurança (CSP) bloqueou também as tentativas diretas.
Alguém consegue roubar dados do usuário pelo site?	Não pelos caminhos testados: envio para domínios não autorizados é bloqueado. Mas os dados de localização vão, por design, para 6+ serviços externos (seção 6, L-08).
O que falhou?	9 vetores, agrupados em 6 limitações de código (todas Baixa ou Média e fáceis de corrigir) e 5 limitações de processo/operação.
Quanto custa corrigir?	As correções de código levam cerca de 1 sessão de trabalho, sem custo. As de processo são configurações do GitHub feitas pelo dono (minutos). Cabeçalhos de servidor dependem da mudança para a AWS.
Este teste substitui um pen test profissional?	Não. É um teste automatizado e honesto, útil para o estágio atual. Antes de vender o produto, contrate um teste profissional independente.

Placar por severidade das limitações

Alta	Média	Baixa	Informativa	Vetores que resistiram
1	4	5	1	33/42

2. Escopo e metodologia (OSSTMM 3)

O OSSTMM organiza a segurança em **canais** (humano, físico, sem fio, telecomunicações e redes de dados) e mede três coisas: **porosidade** (por onde se pode interagir com o alvo: visibilidade, acesso e confiança), **controles** (10 tipos de proteção) e **limitações** (o que falha ou falta, classificadas como vulnerabilidade, fraqueza, preocupação, exposição ou anomalia).

Canal OSSTMM	No escopo?	Observação
Redes de dados — aplicação web	Sim	Site estático (HTML/CSS/JS) e as 9 integrações externas
Redes de dados — processos (repositório, CI)	Sim	Configurações verificáveis pela API do GitHub; dependências e histórico
Humano (engenharia social)	Não	Ex.: golpe de phishing na conta do dono — recomendado autenticação em 2 fatores
Físico, sem fio, telecomunicações	Não	Não se aplicam a um site estático
Servidor de hospedagem (GitHub Pages)	Parcial	O ambiente de teste não acessa o endereço publicado; cabeçalhos do servidor avaliados por documentação, não por medição

Fases executadas

Fase	O que foi feito
1. Regras e indução	Autorização do dono; sem dano; serviços externos simulados (não atacamos terceiros)
2. Informação (visibilidade)	Leitura do código, mapa de entradas de dados, serviços contatados, armazenamento local, service worker
3. Acesso	13 vetores pelo endereço do site (links de cidade, viagem, parâmetros)
4. Confiança	7 serviços externos devolvendo respostas maliciosas (nomes, alertas, previsão com tipos errados, domínio falso)
5. Controles	CSP, scripts de terceiros, links, transporte, Referer, clickjacking por iframe, arquivos gerados (.ics, e-mail)
6. Processos	Proteção de ramo, relato privado de falhas, alertas de dependência, npm audit, busca de segredos no histórico do git
7. Resiliência	Entradas gigantes, digitação em rajada, dados corrompidos

Ferramentas: navegador Chromium automatizado (Playwright), análise estática do código, API do GitHub, npm audit. O roteiro está em `tests/pentest.test.js` e pode ser repetido a cada versão.

3. Superfície de ataque (porosidade)

Ponto de interação	Tipo OSSTMM	Quem controla	Proteção encontrada
Link de cidade (?cidade=□=&lon;=)	Acesso	Qualquer pessoa	Texto, limite de 80 letras, validação de faixa
Link de viagem (?viagem=1...)	Acesso	Qualquer pessoa	Nomes limpos e cortados, veículo só da lista, coordenadas validadas
Parâmetros ?demo= e ?debug=	Acesso	Qualquer pessoa	Só valores conhecidos; texto
Busca de cidades (Open-Meteo)	Confiança	Terceiro	Texto (nunca HTML); CSP
Busca de endereços (Photon/OSM)	Confiança	Terceiro	Limpeza de caracteres de controle; texto
Nomes por coordenada (BigDataCloud)	Confiança	Terceiro	Texto; CSP
Alertas oficiais (NWS)	Confiança	Terceiro	Texto; CSP
Rotas (OSRM) e postos (Overpass/OSM)	Confiança	Terceiro	Texto, inclusive nas dicas do mapa
Radar (RainViewer)	Confiança	Terceiro	CSP limita de onde vêm imagens (ver L-05)
Armazenamento do aparelho (localStorage)	Confiança	Usuário / quem tem o aparelho	Validação de tipo; texto (ver L-04)
Repositório e publicação (GitHub)	Acesso	Dono da conta	CodeQL, CI com permissão mínima (ver L-01, L-02)

4. Controles OSSTMM

Controle	Situação	Evidência
Autenticação	Não se aplica	Não há contas de usuário. Para o GitHub: 2 fatores não verificável daqui (ação do dono)
Indenização (termos, responsabilidade)	Ausente	Sem termos de uso nem política de privacidade publicados (necessários antes de vender)
Resiliência	Bom	Falha de um serviço não derruba os outros; entradas gigantes e corrompidas tratadas (exceto L-04)
Subjugação (só funciona do jeito previsto)	Bom	Veículo, demo, unidades, idioma só aceitam valores conhecidos (exceto L-04, L-06)
Continuidade	Fraco	Serviços gratuitos sem garantia (OSRM demo, Overpass, Photon) — L-11
Não repúdio	Não se aplica	Não há transações
Confidencialidade	Bom	HTTPS; envio a domínios não autorizados bloqueado (K5); Referer só com a origem (K8)
Privacidade	Atenção	Localização/endereço vão a terceiros por design; casa salva em texto no aparelho — L-08
Integridade	Bom, com ressalva	Sem scripts de terceiros; Leaflet no próprio site; injeção em .ics/e-mail — L-03
Alarme	Parcial	CodeQL e testes no GitHub avisam; relato privado de falhas desligado — L-02

5. Limitações encontradas

Classificação OSSTMM: **Vulnerabilidade** (permite acesso ou ação indevida), **Fraqueza** (falha num controle), **Preocupação** (falha de processo/operação), **Exposição** (informação visível que ajuda um ataque ou fere a privacidade), **Anomalia** (comportamento inesperado sem dano direto).

ID	Severidade	Tipo	Limitação
L-01	Alta	Fraqueza	Ramo principal (main) do repositório sem proteção
L-02	Média	Preocupação	Alarmes de segurança do repositório desligados e 5 atualizações pendentes
L-03	Média	Vulnerabilidade	Quebra de linha no nome de uma cidade injeta campos no convite de calendário e no e-mail
L-04	Baixa	Anomalia	Valor "interno" do JavaScript no armazenamento derruba o site
L-05	Baixa	Fraqueza	Endereço das imagens do radar vem do serviço externo sem validação
L-06	Info	Anomalia	Coordenadas vazias ou em hexadecimal aceitas no link de cidade
L-07	Baixa	Fraqueza	Sem cabeçalhos de segurança de servidor (limitação do GitHub Pages)
L-08	Média	Exposição	Localização e endereços enviados a terceiros; casa salva em texto no aparelho
L-09	Baixa	Fraqueza	CSP permite estilo inline e imagens data:/blob:
L-10	Baixa	Preocupação	Modo sem internet guarda cada variação de endereço e as buscas feitas
L-11	Média	Preocupação	Continuidade: serviços gratuitos sem garantia

L-01 · Ramo principal (main) do repositório sem proteção

Severidade: **Alta** · Tipo OSSTMM: **Fraqueza**

Evidência. API do GitHub: *branches/main* → *protected: false*. Qualquer envio direto ao main publica o site na hora, sem testes obrigatórios e sem revisão. Se a conta (ou o app com acesso) for comprometida, o atacante troca o site e engana todos os usuários.

Recomendação. Ativar proteção do main: exigir que os testes passem e bloquear "force push". Ativar 2 fatores na conta. Limitar o app do Claude só a este repositório.

L-02 · Alarmes de segurança do repositório desligados e 5 atualizações pendentes

Severidade: **Média** · Tipo OSSTMM: **Preocupação**

Evidência. API: relato privado de vulnerabilidades *enabled: false*; alertas do Dependabot *desabilitados*; 5 pedidos de atualização do Dependabot abertos sem aprovação (checkout, codeql-action, setup-node, upload-artifact, playwright). npm audit: 0 vulnerabilidades hoje. Nenhum segredo encontrado no histórico do git.

Recomendação. Ativar "Private vulnerability reporting" e "Dependabot alerts" (Settings → Code security). Revisar e aprovar as 5 atualizações.

L-03 · Quebra de linha no nome de uma cidade injeta campos no convite de calendário e no e-mail

Severidade: **Média** · Tipo OSSTMM: **Vulnerabilidade**

Evidência. Vetores F1/F2: um nome devolvido pela busca de cidades com caractere de retorno (\r) gerou no arquivo .ics uma linha falsa "ATTENDEE:mailto:atacante@..." e um %0D no assunto do e-mail. Exige que o serviço de busca seja comprometido ou devolva dado malicioso. Nomes vindos de links já eram limpos.

Recomendação. Remover caracteres de controle de TODOS os nomes externos ao recebê-los (não só os do link e do Photon) e tratar \r isolado no gerador de .ics.

L-04 · Valor "interno" do JavaScript no armazenamento derruba o site

Severidade: **Baixa** · Tipo OSSTMM: **Anomalia**

Evidência. Vetor S2: idioma salvo como "constructor", "__proto__", "toString" ou "hasOwnProperty" faz o site parar de carregar (erro "reading locale") até limpar os dados do navegador. Exige acesso ao aparelho ou outra falha prévia.

Recomendação. Checar valores com Object.hasOwnProperty() no idioma, unidades e demo; cair no padrão se inválido.

L-05 · Endereço das imagens do radar vem do serviço externo sem validação

Severidade: **Baixa** · Tipo OSSTMM: **Fraqueza**

Evidência. Vetor C7: com resposta adulterada, o site tentou buscar imagens em "evil.example.com". A política CSP bloqueou (img-src), então não houve dano — o controle funcionou, mas a validação deveria existir antes.

Recomendação. Aceitar só o host oficial (tilecache.rainviewer.com) e caminhos no formato esperado.

L-06 · Coordenadas vazias ou em hexadecimal aceitas no link de cidade

Severidade: **Info** · Tipo OSSTMM: **Anomalia**

Evidência. Vetor A2: lat= e lon= vazios viram 0,0 (oceano Atlântico) e "0x2A" vira 42. Sem risco de segurança; pode confundir quem recebe um link quebrado.

Recomendação. Aceitar só números decimais e ignorar o link se o formato não bater.

L-07 · Sem cabeçalhos de segurança de servidor (limitação do GitHub Pages)

Severidade: **Baixa** · Tipo OSSTMM: **Fraqueza**

Evidência. Não é possível enviar frame-ancestors, X-Content-Type-Options, Permissions-Policy nem controlar HSTS no GitHub Pages. O script anti-clickjacking funcionou no teste (K10: o site saiu do iframe do "site malicioso"), mas depende de JavaScript.

Recomendação. Na AWS (CloudFront): cabeçalhos HSTS, CSP com frame-ancestors 'none', nosniff e Permissions-Policy — já previstos em docs/07-seguranca.md.

L-08 · Localização e endereços enviados a terceiros; casa salva em texto no aparelho

Severidade: **Média** · Tipo OSSTMM: **Exposição**

Evidência. Ao usar o site, coordenadas vão para Open-Meteo, BigDataCloud, NWS, RainViewer (área do mapa) e, na viagem, OSRM, Overpass e Photon (endereço digitado). O Referer não vaza a página completa (K8). O endereço de casa fica legível no armazenamento do navegador de quem tem o aparelho.

Recomendação. Publicar política de privacidade listando os serviços; botão "apagar meus dados" (casa, recentes, favoritas). Antes de cobrar: revisar os termos de cada serviço.

L-09 · CSP permite estilo inline e imagens data:/blob:

Severidade: **Baixa** · Tipo OSSTMM: **Fraqueza**

Evidência. style-src 'unsafe-inline' e img-src data: blob: são necessários hoje (mapa e radar desenhados no aparelho). Ampliam um pouco o que um atacante poderia fazer se outra falha existisse; não houve exploração.

Recomendação. Na AWS, avaliar nonce/hash para estilos e restringir blob: ao mínimo.

L-10 · Modo sem internet guarda cada variação de endereço e as buscas feitas

Severidade: **Baixa** · Tipo OSSTMM: **Preocupação**

Evidência. O service worker guarda toda página do próprio site com qualquer parâmetro (?cidade=...) e as respostas de busca, sem limite. O armazenamento cresce e o histórico de buscas fica no aparelho.

Recomendação. Guardar a página sem parâmetros (ignoreSearch) e limitar/expirar o cache de dados.

L-11 · Continuidade: serviços gratuitos sem garantia

Severidade: **Média** · Tipo OSSTMM: **Preocupação**

Evidência. OSRM (servidor de demonstração), Overpass e Photon podem limitar ou cair sem aviso; a previsão comercial exige plano pago da Open-Meteo. Um terceiro fora do ar tira parte do produto do ar (já aconteceu com o serviço de nomes em 28/09).

Recomendação. Fase AWS: intermediário com cache e serviços com contrato; monitorar disponibilidade.

6. Plano de correção recomendado

Prioridade	Ação	Quem	Esforço	Resolve
1 · agora	Proteger o ramo main, ativar 2 fatores, limitar o app do Claude a este repositório	Dalmo (GitHub)	Minutos	L-01
2 · agora	Ativar relato privado e alertas do Dependabot; aprovar as 5 atualizações	Dalmo / Claude	Minutos	L-02
3 · próxima versão	Limpar nomes externos e .ics; Object.hasOwn; validar host do radar e coordenadas; cache do modo sem internet	Claude	~1 sessão	L-03 a L-06, L-10
4 · antes de vender	Política de privacidade, termos de uso, botão "apagar meus dados"	Dalmo + Claude	1-2 sessões	L-08, indenização
5 · fase AWS	Cabeçalhos de servidor, CSP mais restrita, intermediário com cache e serviços com contrato	Claude + Dalmo	Projeto	L-07, L-09, L-11
6 · antes de vender	Pen test profissional independente	Empresa especializada	Contratar	Validação externa

7. Limites deste teste (honestidade)

- O teste foi feito por uma IA, de forma automatizada, sobre uma cópia local idêntica ao código publicado. O ambiente de teste não alcança o endereço público, então o servidor do GitHub Pages não foi medido diretamente.
- Os serviços externos foram simulados: não atacamos sistemas de terceiros (o que seria ilegal sem autorização deles).
- Canais humano (golpes contra o dono), físico e sem fio ficaram fora do escopo. A maior ameaça realista — roubo da conta do GitHub — depende de 2 fatores, que não é verificável daqui.
- O cálculo numérico completo do OSSTMM (RAV) exige a planilha oficial e medições do servidor; este relatório traz a análise qualitativa de porosidade, controles e limitações.
- "Resistiu" significa que o vetor testado não teve sucesso; não prova que não exista outro caminho.

Apêndice A — os 42 vetores testados

ID	Área (OSSTMM)	Vetor	Resultado
A1	Acesso · link de cidade	código no nome/região/país da cidade no link	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=1e309 lon=0	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=NaN lon=0	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=91 lon=0	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=0 lon=-181	RESISTIU
A2	Acesso · link de cidade	coordenada inválida lat=0x2A lon=10	FALHOU (Baixa)
A2	Acesso · link de cidade	coordenada inválida lat= lon=	FALHOU (Baixa)
A3	Acesso · link de viagem	código nos nomes, horário e veículo do link de viagem	RESISTIU
A4	Acesso · link de viagem	veículo desconhecido no link	RESISTIU
A5	Acesso · link de viagem	coordenadas/horário absurdos no link de viagem	RESISTIU
A6	Acesso · link de cidade	nome gigante (5.000 letras) no link	RESISTIU
A7	Acesso · parâmetro demo	?demo=__proto__	RESISTIU
A7	Acesso · parâmetro demo	?demo=constructor	RESISTIU
A7	Acesso · parâmetro demo	?demo=toString	RESISTIU
A7	Acesso · parâmetro demo	?demo=<img src=x onerror="window.__x	RESISTIU
C1	Confiança · busca de cidades (Open-Meteo)	código nos nomes devolvidos pela busca	RESISTIU
C2	Confiança · busca de cidades (Open-Meteo)	código no nome depois de escolher a cidade (título, barra, favoritos)	RESISTIU
C3	Confiança · busca de endereços (Photon)	código em rua/número/cidade devolvidos	RESISTIU
C4	Confiança · alertas oficiais (NWS)	código no texto do alerta oficial	RESISTIU
C5	Confiança · postos/balanças (Overpass) e nomes no caminho (BigDataCloud)	código nos nomes de postos, balanças e cidades do caminho, inclusive nas dicas do mapa	RESISTIU
C6	Confiança · previsão (Open-Meteo)	previsão com tipos errados/código no lugar de números	RESISTIU
C7	Confiança · radar (RainViewer)	serviço de radar manda buscar imagens em outro domínio	FALHOU (Média)
S1	Armazenamento local	código em cidade salva, favoritas, viagens recentes, casa, unidades e idioma	RESISTIU
S2	Armazenamento local	idioma/unidade salvos como "constructor" (palavra interna do JavaScript)	FALHOU (Baixa)
S2	Armazenamento local	idioma/unidade salvos como "__proto__" (palavra interna do JavaScript)	FALHOU (Baixa)
S2	Armazenamento local	idioma/unidade salvos como "toString" (palavra interna do JavaScript)	FALHOU (Baixa)
S2	Armazenamento local	idioma/unidade salvos como "hasOwnProperty" (palavra interna do JavaScript)	FALHOU (Baixa)
S3	Armazenamento local	dados corrompidos (não-JSON, tipos errados)	RESISTIU
K1	Controles · integridade	scripts de terceiros carregados na página	RESISTIU
K2	Controles · CSP	script inserido na página é bloqueado pela política (CSP)	RESISTIU
K3	Controles · CSP	atributo de evento injetado no HTML (onerror=...) é bloqueado	RESISTIU
K4	Controles · CSP	script de outro domínio bloqueado	RESISTIU

ID	Área (OSSTMM)	Vetor	Resultado
K5	Controles · CSP	envio de dados para domínio não autorizado (fetch) bloqueado	RESISTIU
K6	Controles · links externos	links que abrem nova aba sem rel=noopener (tabnabbing)	RESISTIU
K7	Controles · transporte	recursos por http (sem criptografia) no HTML	RESISTIU
K8	Privacidade · cabeçalho Referer	site manda a página completa (com cidade/viagem) para terceiros	RESISTIU
K9	Privacidade · terceiros	serviços externos contatados ao abrir	RESISTIU
K10	Controles · clickjacking	outro site embute o nosso num iframe invisível	RESISTIU
F1	Integridade · arquivo de calendário (.ics)	quebra de linha no nome da cidade cria campo falso no convite (ex.: convidado do atacante)	FALHOU (Média)
F2	Integridade · e-mail (mailto)	cabeçalhos extras no e-mail (cc/bcc) a partir do nome	FALHOU (Baixa)
R1	Resiliência	busca com 5.000 letras	RESISTIU
R2	Resiliência	digitação muito rápida (30 letras) não vira 30 consultas	RESISTIU

Serviços externos contatados ao abrir o site (vetor K9): api.open-meteo.com, air-quality-api.open-meteo.com, api.weather.gov